

Tabla de Congruencia

Nombre: Luis Alberto Vargas Gonzalez.

Título del proyecto: Diseño e Implementación de un Plan de Respuesta a Incidentes (IRP) Especializado para la Plataforma Canvas y Servicios de Autenticación de la Universidad Digital de las Américas (UDA).

A través de diversas técnicas para diagnosticar la problemática, obtuviste información valiosa que te permitió conocer el estatus de tu proceso a intervenir, por ejemplo, puedes reconocer las causas de la problemática o las debilidades que se manifiestan.

La información te permitirá alinear los hallazgos con un plan de acción congruente con el diagnóstico.

Escribe en la columna de la izquierda los resultados del diagnóstico y en la columna de la derecha las acciones que se realizarán para resolverlos.

Es importante señalar que también podemos identificar en el diagnóstico buenas prácticas, por lo tanto, las acciones pueden consistir en dar seguimiento para mantener el estatus.

Asimismo, nos podemos encontrar con algunas situaciones que no representen una problemática, pero pueden ser susceptibles de mejora.

Tabla de Congruencia Entre el Diagnóstico y las Acciones a Realizar	
Problemática o situación de mejora identificada (Causas, debilidades, etc.)	Acciones que se realizarán
Hallazgo 1: Inexistencia de un Plan de Respuesta a Incidentes (IRP) formalizado, acompañada de la ausencia de una matriz de gobernanza y escalación de crisis que defina la cadena de mando entre el equipo de TI, el CISO y la Rectoría, lo que ocasiona retrasos de 45 a 90 minutos solo en la coordinación inicial.	Acción 1: Formular el marco de gobernanza, las políticas de comunicación de crisis y la matriz de escalación formal con cuatro niveles de severidad para el IRP de la UDA, delimitando las facultades legales y técnicas de cada rol institucional ante eventos adversos.
Hallazgo 2: Ausencia de <i>playbooks</i> tácticos estandarizados para responder ante vectores de ataque de alta criticidad, como el secuestro de credenciales administrativas (<i>Account Takeover</i>) y el cifrado de bases de datos por Ransomware en la plataforma LMS Canvas.	Acción 2: Diseñar y documentar <i>playbooks</i> tácticos hiper-específicos dotados de flujos de contención automatizada mediante scripts en AWS Lambda para el aislamiento inmediato de subredes comprometidas en Canvas y la revocación masiva de tokens de sesión.
Hallazgo 3: Respuesta manual, reactiva e ineficiente ante picos de tráfico masivo por ataques de Denegación de Servicio Distribuido (DDoS) contra el portal de autenticación SSO, generando indisponibilidad del servicio y riesgos de incumplimiento de la LFPDPPP.	Acción 3: Configurar e integrar reglas elásticas de filtrado perimetral en AWS WAF junto con mecanismos de telemetría y alerta automatizada en AWS CloudWatch para la mitigación oportuna de inundaciones de tráfico en el portal SSO.